SOC Questions

1) Explain password management in cyber security.

1. **Definition of Password Management**
   Password management is the process of **creating, storing, and managing passwords securely** for different systems and accounts. It helps users access services safely while protecting sensitive information.
2. **Protection of Sensitive Data**
   Password management protects **confidential data, files, and systems** from unauthorized users. Strong password practices reduce the chances of hacking or data breaches.
3. **Use of Password Managers**
   A password manager is a **software tool that securely stores passwords in an encrypted form**. It allows users to save and manage many passwords in one secure place.
4. **Master Password System**
   Most password managers work with a **single master password**. This master password allows users to unlock and access all other stored passwords securely.
5. **Creation of Strong Passwords**
   Password management tools help generate **complex and strong passwords** using letters, numbers, and symbols. Strong passwords are difficult for attackers to guess or crack.
6. **Centralized Password Storage**
   All passwords are stored in **one centralized and secure location**. This makes it easier for users or organizations to manage multiple accounts efficiently.
7. **Automatic Login Feature**
   Many password managers provide **autofill or automatic login features**. This helps users sign in quickly without manually typing passwords each time.
8. **Prevention of Password Reuse**
   Password management encourages using **different passwords for different accounts**. This prevents attackers from accessing multiple accounts if one password is compromised.
9. **Enforcement of Security Policies**
   Organizations use password management to **enforce security rules** like password complexity, minimum length, and regular password changes.
10. **Improved Cyber Security**
    Overall, password management strengthens **authentication and system security**. It plays an important role in protecting digital assets and maintaining cybersecurity in organizations.

2) Issues related Password Management

1. **Login Spoofing**

   Login spoofing occurs when attackers create fake login pages or websites that look like real ones. When users enter their username and password, the attacker captures the credentials and gains unauthorized access.

2. **Sniffing Attack**

   A sniffing attack happens when hackers intercept network traffic to capture login information. If passwords are transmitted without proper encryption, attackers can easily steal them.

3. **Brute Force Attack**

   In a brute force attack, attackers use automated tools to guess passwords repeatedly until the correct one is found. Weak or short passwords are easier to crack using this method.

4. **Shoulder Surfing Attack**

   Shoulder surfing occurs when someone physically watches a user entering their password on a device. This usually happens in public places like offices, cafes, or libraries.

5. **Data Breach**

   A data breach happens when hackers gain unauthorized access to databases containing user credentials. If passwords are not properly encrypted, attackers can steal and misuse them.

6. **Password Reuse**

   Many users use the same password for multiple accounts. If one account is hacked, attackers can access other accounts easily.

7. **Difficulty in Remembering Passwords**

   Users often have many online accounts, making it hard to remember different strong passwords for each service.

8. **Weak Passwords**

People sometimes create simple passwords like “123456” or “password”, which are easy for attackers to guess.

3) **Identify and access management.**

Identity and Access Management (IAM) is a system of **policies, processes, and technologies** used by organizations to manage digital identities and control user access to resources. It ensures that **only authorized users can access specific systems, applications, or data** within an organization.

IAM helps organizations **identify users, verify their identity, and grant appropriate permissions** based on their roles. It is widely used in cloud platforms, enterprise networks, and applications to maintain security and enforce the **principle of least privilege** (users only get access they need).

Components of Identity and Access Management

1. **Users**

   Users are individuals such as **employees, administrators, or customers** who need access to systems or services in an organization.

2. **Roles**

   Roles define the **type of access or permissions assigned to a user** based on their job responsibilities.

3. **Groups**

   Groups are collections of users who **share similar access permissions**, making it easier to manage multiple users at once.

4. **Policies**

   Policies are **rules that define what actions users or groups are allowed or not allowed to perform** within a system.

Importance of IAM

- Controls and monitors user access to resources.
- Protects sensitive organizational data.
- Ensures only authorized users can access systems.
- Simplifies management of permissions in large organizations.

4) Classifications of IAM.

Identity and Access Management (IAM) identities are mainly classified into **three types: IAM Users, IAM Groups, and IAM Roles**. These classifications help organizations manage user access and permissions efficiently.

1. IAM Users

IAM users are **individual identities created in a system** to access services and resources. Each user has their own login credentials and permissions assigned by the administrator.

2. IAM Groups

IAM groups are **collections of IAM users** who share the same permissions. Instead of assigning permissions to each user individually, permissions can be assigned to the group.

3. IAM Roles

IAM roles are **temporary identities that provide permissions to perform specific tasks**. Roles can be assumed by users, applications, or services when needed.

5) access management for AWS resources identity Management.

Access Management for AWS Resources – Identity Management

1. **User Identity Management** – AWS Identity and Access Management (IAM) allows organizations to create and manage user identities who can access AWS services and resources securely.
2. **Authentication and Authorization** – IAM verifies the identity of users through authentication and controls what actions they can perform using authorization policies.

3. **IAM Users and Groups** – Administrators can create individual IAM users and organize them into groups to manage permissions efficiently across multiple users.
4. **Role-Based Access Control (RBAC)** – IAM roles allow temporary permissions to users, applications, or services without sharing long-term credentials.
5. **Policy Management** – IAM policies define permissions in JSON format and specify which AWS resources a user or role can access and what actions are allowed.
6. **Multi-Factor Authentication (MFA)** – IAM supports MFA to add an extra layer of security, requiring users to verify identity with a second authentication factor.
7. **Least Privilege Principle** – AWS IAM follows the least privilege model where users are granted only the permissions necessary to perform their tasks.
8. **Access Monitoring and Auditing** – AWS services like CloudTrail and IAM Access Analyzer help monitor user activity and detect unusual or unauthorized access attempts.
9. **Secure Access to AWS Resources** – IAM ensures that access to resources such as EC2, S3, and databases is controlled, secure, and compliant with organizational policies.

6) Benefits of IAM.

Benefits of Identity and Access Management (IAM)

1. **Improved Security** – IAM enhances organizational security by ensuring that only authenticated and authorized users can access systems, applications, and sensitive resources. It reduces the risk of unauthorized access and cyber threats.
2. **Centralized Access Control** – IAM provides a centralized platform to manage user identities and permissions across multiple systems and services. This simplifies administration and ensures consistent security policies across the organization.
3. **Better Compliance and Auditing** – IAM helps organizations meet regulatory and security compliance requirements by maintaining detailed logs of user activities. These records support auditing, monitoring, and reporting of access-related actions.
4. **Principle of Least Privilege** – IAM allows administrators to assign only the necessary permissions required for users to perform their tasks. This reduces the chances of misuse or accidental exposure of sensitive information.
5. **Enhanced User Productivity** – IAM solutions often support features like Single Sign-On (SSO), allowing users to access multiple systems with one login. This reduces login complexity and improves overall work efficiency.
6. **Reduced Risk of Insider Threats** – By monitoring and controlling user access to resources, IAM helps detect suspicious activities or misuse by internal users. This improves overall security visibility.
7. **Scalable User Management** – IAM systems can efficiently manage thousands of users, devices, and applications as organizations grow. This scalability ensures secure access management in large enterprises.
8. **Automated Access Provisioning** – IAM can automate the process of granting and revoking access rights when employees join, change roles, or leave the organization. This ensures proper access control and reduces administrative workload.

7) Importance of IAM for organization

Importance of Identity and Access Management (IAM) for Organizations

1. **Enhances Organizational Security** – IAM ensures that only authorized users can access organizational systems, applications, and sensitive data. This reduces the risk of cyberattacks, data breaches, and unauthorized access.
2. **Protects Sensitive Information** – IAM helps safeguard confidential business data, customer information, and intellectual property by controlling who can view, modify, or share the data within the organization.
3. **Supports Regulatory Compliance** – IAM helps organizations meet regulatory requirements and security standards by maintaining proper access control, monitoring user activities, and keeping detailed audit logs.
4. **Improves Access Control Management** – IAM allows administrators to manage user identities, permissions, and roles from a centralized system. This simplifies the management of access rights across multiple systems.
5. **Reduces Insider Threats** – By monitoring user access and restricting unnecessary permissions, IAM helps organizations prevent misuse of resources by employees or internal users.
6. **Increases Operational Efficiency** – IAM systems automate user account management, access provisioning, and deprovisioning. This reduces manual administrative work and improves overall IT efficiency.
7. **Supports Remote and Cloud Access** – IAM enables secure access to cloud services, applications, and remote systems, allowing employees to work securely from different locations.
8. **Improves Accountability and Monitoring** – IAM keeps track of user activities and access records, helping organizations identify suspicious behavior and respond quickly to potential security incidents.

8) IAM Technology and tools

IAM Technologies and Tools

1. **Single Sign-On (SSO)** – SSO technology allows users to log in once and access multiple applications without repeatedly entering credentials. This improves user convenience while maintaining centralized authentication control.
2. **Multi-Factor Authentication (MFA)** – MFA adds additional verification methods such as OTPs, biometrics, or security tokens along with passwords. This extra layer of security helps prevent unauthorized access to systems and data.

3. **Access Management Tools** – Access management tools control who can access specific systems, resources, or applications. These tools enforce policies that define permissions based on user roles and responsibilities.
4. **Identity Governance and Administration (IGA)** – IGA tools help manage the lifecycle of user identities including provisioning, role management, and access reviews. They ensure that users have the correct level of access at all times.
5. **Privileged Access Management (PAM)** – PAM tools manage and secure privileged accounts such as administrators or system managers. They monitor and control high-level access to reduce the risk of misuse.
6. **Authentication Services** – Authentication technologies verify the identity of users before granting system access. Methods include passwords, smart cards, biometric authentication, and security tokens.
7. **Cloud-based IAM Solutions** – Many organizations use cloud IAM platforms such as AWS IAM or Azure Active Directory to manage identities and permissions across cloud services. These tools provide scalable and flexible access management.
8. **Audit and Monitoring Tools** – IAM systems include logging and monitoring tools that track user access and activities. These logs help detect suspicious behavior and support security audits and compliance requirements.

9) Features of IAM.

Features of Identity and Access Management (IAM)

1. **User Identity Management** – IAM allows organizations to create, manage, and maintain digital identities for users such as employees, partners, and customers within the system.
2. **Authentication Mechanism** – IAM verifies the identity of users before granting access through methods like passwords, biometrics, smart cards, or multi-factor authentication.
3. **Authorization and Access Control** – IAM controls what resources or systems a user can access based on predefined roles, permissions, and organizational policies.
4. **Role-Based Access Control (RBAC)** – IAM assigns access rights based on user roles within the organization, ensuring users receive permissions according to their job responsibilities.
5. **Single Sign-On (SSO)** – IAM supports SSO, enabling users to log in once and access multiple applications or systems without repeated authentication.
6. **Multi-Factor Authentication (MFA)** – IAM includes MFA to provide an additional layer of security by requiring more than one verification method during login.
7. **User Provisioning and De-provisioning** – IAM automates the process of granting, modifying, and removing user access when employees join, change roles, or leave the organization.
8. **Audit and Monitoring** – IAM systems maintain logs of user activities and access attempts, helping organizations monitor security events and detect suspicious behavior.
9. **Policy Management** – IAM allows administrators to define and enforce security policies that regulate how users access systems, applications, and organizational data.

10) Key Component of a SOC

Key Components of a Security Operations Center (SOC)

1. **People** – SOC includes skilled professionals such as SOC analysts, SOC managers, and incident response teams who monitor security alerts, investigate threats, and respond to cyber incidents to protect the organization. SOC analysts are often divided into Tier-1, Tier-2, and Tier-3 based on expertise.
2. **Technology** – SOC uses various security technologies such as SIEM (Security Information and Event Management), EDR (Endpoint Detection and Response), IDPS (Intrusion Detection and Prevention Systems), firewalls, and threat intelligence tools to collect logs, monitor network activities, detect malicious behavior, and protect systems from cyber attacks.
3. **Processes** – SOC follows defined security processes like incident detection and response, threat hunting, security monitoring, and forensic analysis to identify, investigate, and mitigate security incidents effectively.
4. **Physical Infrastructure** – SOC requires secure facilities and reliable infrastructure such as dedicated monitoring centers, backup systems, and redundant data centers to ensure continuous security operations.
5. **Communication and Collaboration Tools** – SOC teams use alerting systems, ticketing platforms, and collaboration tools to share information, coordinate incident response, and ensure quick communication between security teams.

11) SOC Models

SOC Models

1. **In-House SOC (On-Premises SOC)** – In this model the organization builds and operates its own SOC using internal staff, tools, and infrastructure. It provides full control over security operations but requires high cost, skilled experts, and continuous maintenance.
2. **Managed SOC (MSSP -** Managed Security Service Provider**)** – In this model a third-party Managed Security Service Provider handles monitoring, threat detection, and incident response. It helps organizations that lack internal resources or expertise to manage security operations.
3. **Hybrid SOC** – Hybrid SOC combines internal security teams with external service providers. The organization manages critical security tasks internally while outsourcing monitoring or support services to third-party experts.
4. **Virtual SOC (vSOC)** – A virtual SOC operates remotely using cloud platforms and distributed security teams. This model provides flexibility, scalability, and reduces the need for a dedicated physical SOC facility.

5. **Cloud SOC** – Cloud SOC focuses on protecting cloud infrastructure and applications. It uses cloud-based monitoring tools and integrates with services such as AWS or Azure security platforms to detect and respond to threats.
6. **Co-Managed SOC** – In this model the organization's internal security team works together with an external security provider. Both teams share responsibilities for monitoring, threat analysis, and incident response to improve overall security operations.

12) SOC Challenges

SOC Challenges

1. **Staffing Shortage** – Many organizations face difficulty in finding trained and experienced SOC professionals. The rapid growth of cloud infrastructure and modern technologies makes it harder to recruit and afford skilled security staff.
2. **Skills Shortage** – Even when staff are available, they may lack specialized cybersecurity skills required to operate monitoring and management tools effectively. This can lead to slow responses and sometimes failure to stop security threats.
3. **Knowledge Shortage** – SOC teams may not fully understand the systems and environments they are protecting. Limited knowledge can cause incorrect threat analysis, leading to false positives, false negatives, and delayed responses to real attacks.
4. **Process Latency** – SOC processes may not evolve quickly enough to match changes in technology and IT environments. This delay causes inefficient workflows and forces teams to improvise responses during security incidents.
5. **Budget Allocation Issues** – Some organizations allocate security budgets based on general IT spending instead of actual security risks. This approach may lead to insufficient investment in protecting the most critical systems.
6. **Lack of Adequate Tooling** – Rapid changes in technologies like cloud computing and containerized applications require new security tools. Without proper tools, SOC teams may lack visibility and control over certain systems.
7. **Inadequate Analytics and Filtering** – Security tools sometimes generate large numbers of alerts, including many false positives. Poor analytics and filtering make it difficult for SOC analysts to identify real threats efficiently.
8. **Lack of Automation and Integration** – Many SOC operations still depend heavily on manual processes. Without automation and integration between tools, incident response becomes slow, error-prone, and increases workload for analysts.

13) Benefit of Enterprises Mobility Management.

Benefits of Enterprise Mobility Management (EMM)

1. **Improved Data Security** – EMM protects organizational data on mobile devices by enforcing security policies such as password protection, encryption, and remote wipe if a device is lost or stolen.
2. **Better Device Management** – IT administrators can centrally monitor, configure, and control employee devices such as smartphones, tablets, and laptops used for business purposes.
3. **Support for Remote Work** – EMM allows employees to securely access company emails, applications, and documents from anywhere, enabling flexible and remote working environments.
4. **Increased Productivity** – Employees can work more efficiently using mobile devices to perform tasks, communicate with teams, and access business resources quickly.
5. **Application Control** – Organizations can install, update, and remove business applications remotely, ensuring employees only use approved and secure applications.
6. **Cost Efficiency** – EMM reduces the need for additional hardware and manual device management, helping organizations save costs related to IT infrastructure and maintenance.
7. **Compliance and Policy Enforcement** – EMM helps organizations enforce security policies and meet regulatory requirements by controlling how devices and applications access company data.
8. **Data Backup and Recovery** – EMM solutions provide secure backup and recovery options for business data stored on mobile devices, ensuring important information can be restored in case of device loss, damage, or system failure.

14) Difference between of MDM(Mobile Device Management) and EMM(Enterprised Mobility Management)

Difference Between MDM and EMM

Basis	MDM (Mobile Device Management)	EMM (Enterprise Mobility Management)
Definition	MDM is used to manage and secure mobile devices like smartphones and tablets in an organization.	EMM is a broader system used to manage mobile devices, applications, content, and user access. soc EMM
Scope	MDM focuses mainly on controlling and securing the device itself.	EMM covers devices, applications, data, and identity management. soc EMM
Device Control	Provides features like remote lock, remote wipe, and device tracking.	Includes device control along with additional enterprise mobility services. soc EMM
Application Management	Limited support for managing mobile applications.	Includes Mobile Application Management (MAM) to control apps and updates. soc EMM
Content Management	Does not strongly focus on managing business files and documents.	Includes Mobile Content Management (MCM) to secure company data and documents. soc EMM
Identity Management	Provides limited identity and access control features.	Integrates Identity and Access Management (IAM) for secure user authentication. soc EMM
Security Level	Provides basic device-level security policies.	Provides advanced security including encryption and access control. soc EMM
Purpose	Focuses mainly on managing mobile devices.	Focuses on managing the entire mobile ecosystem in an enterprise. soc EMM

15) Component of EMM.

Components of Enterprise Mobility Management (EMM)

1. **Mobile Device Management (MDM)** – MDM is used to manage and monitor mobile devices such as smartphones, tablets, and laptops. It allows administrators to configure device settings, enforce security policies, and remotely lock or wipe devices if needed.
2. **Mobile Application Management (MAM)** – MAM focuses on managing and controlling the applications installed on mobile devices. It enables organizations to install, update, and remove applications while ensuring that only approved business apps are used.
3. **Mobile Content Management (MCM)** – MCM helps manage and secure business documents and files on mobile devices. It allows employees to access company files securely and prevents unauthorized sharing or copying of sensitive data.
4. **Identity and Access Management (IAM)** – IAM ensures that only authorized users can access company resources, applications, and data. It uses authentication methods like passwords, PINs, and biometric verification to enhance security.
5. **Containerization** – Containerization creates a secure separate environment on mobile devices for storing corporate applications and data. This helps separate personal data from business data and improves security.
6. **Unified Endpoint Management (UEM)** – UEM extends EMM capabilities to manage not only mobile devices but also desktops, laptops, and other endpoints from a single management platform.

16) What is EMM.

Enterprise Mobility Management (EMM)

1. **Definition** – Enterprise Mobility Management (EMM) is a set of technologies and policies used by organizations to manage, secure, and monitor employee mobile devices such as smartphones, tablets, and laptops.
2. **Secure Access to Company Resources** – EMM enables employees to safely access company emails, applications, and documents from mobile devices while maintaining proper security controls.
3. **Device and Application Management** – EMM helps IT administrators remotely manage devices and control business applications to ensure that only authorized and secure apps are used.
4. **Data Protection and Access Control** – EMM protects organizational data using security policies, encryption, and identity management to prevent unauthorized access and data leakage.

17) explain application of vpn and how does vpn work

Applications of VPN(Virtual Private Network)

1. **Bypassing Geographic Restrictions** – VPN allows users to access websites or streaming services that may be restricted in certain regions by masking the user's real IP address.
2. **Protection on Public Wi-Fi** – VPN helps protect users from snooping and cyber attacks when using untrusted public Wi-Fi networks such as those in airports, cafes, or hotels.
3. **Online Privacy Protection** – VPN hides the user's real location and IP address, helping maintain privacy and anonymity while browsing the internet.
4. **Secure File Sharing and Downloading** – VPN protects users from being tracked or logged while performing activities such as downloading or torrenting online content.

How VPN Works

1. **IP Address Identification** – Every device connected to the internet has its own IP address that can be tracked. VPN helps hide this IP address to maintain privacy.
2. **Creation of Secure Pathway** – VPN creates a secure virtual pathway or tunnel between the user's device and the VPN server through the public internet.
3. **Data Encryption** – The data sent through the VPN tunnel is encrypted, making it unreadable to hackers or unauthorized users during transmission.
4. **Secure Data Transmission** – The encrypted data travels through the internet safely to the VPN server before reaching the intended destination.
5. **Protection of User Identity** – Since the VPN hides the original IP address and location, the user's identity and online activities remain private and difficult to trace.
6. **Safe Communication Over Internet** – By creating an encrypted tunnel and hiding user information, VPN ensures secure communication and protects sensitive data from cyber threats.

18) types of vpn

Types of VPN

1. **Remote Access VPN** – Remote Access VPN allows individual users to connect to a private network from a remote location through the internet. It is commonly used by employees to securely access company resources from home or while traveling.
2. **Site-to-Site VPN** – Site-to-Site VPN connects entire networks located in different geographical locations through the internet. It allows branch offices to communicate securely with the main office network.
3. **Intranet VPN** – Intranet VPN is used when multiple branch offices of the same organization need to communicate securely. It connects internal networks of the same company using a secure VPN tunnel.

4. **Extranet VPN** – Extranet VPN allows secure communication between an organization and external partners, suppliers, or customers. It provides limited access to specific company resources.
5. **SSL VPN** – SSL VPN uses Secure Socket Layer encryption to create a secure connection between the user and the network. Users can access applications securely through a web browser.
6. **IPSec VPN** – IPSec VPN uses Internet Protocol Security to encrypt and protect data transmitted over the internet. It is commonly used for secure communication between networks or remote users.

19) what is vpn and features of vpn.

What is VPN (Virtual Private Network)

1. **Definition** – A Virtual Private Network (VPN) is a technology that creates a secure and encrypted connection over the internet to protect data and communication between users and networks.
2. **Secure Communication** – VPN allows users to securely access a private network from a remote location by creating a protected tunnel through the public internet.
3. **Data Encryption** – VPN encrypts the data transmitted between the user and the network, preventing hackers or unauthorized users from accessing sensitive information.
4. **Remote Network Access** – It enables employees or users to connect to their organization's internal network and access resources such as files, servers, and applications securely.

Features of VPN

1. **Data Encryption** – VPN encrypts internet traffic so that sensitive data such as passwords, emails, and business information cannot be intercepted by attackers.
2. **Secure Tunneling** – VPN creates a secure virtual tunnel between the user's device and the VPN server, ensuring that all transmitted data remains protected.
3. **User Authentication** – VPN verifies the identity of users through authentication methods like usernames, passwords, and multi-factor authentication before granting network access.
4. **IP Address Masking** – VPN hides the user's real IP address and replaces it with the VPN server's IP, improving privacy and anonymity.
5. **Secure Remote Access** – VPN allows users to access private networks securely from remote locations such as home or while traveling.
6. **Data Integrity Protection** – VPN ensures that the data transmitted between devices is not modified or tampered with during transmission.

7. **Access Control** – VPN allows organizations to control which users can access specific resources within the network.
8. **Protection on Public Networks** – VPN provides security when using public Wi-Fi networks by protecting data from cyber threats and unauthorized access.

20) difference between site to site vpn and remote access vpn.

Difference Between Site-to-Site VPN and Remote Access VPN

Basis	Site-to-Site VPN	Remote Access VPN
Definition	Site-to-Site VPN connects entire networks at different locations through a secure VPN tunnel over the internet.	Remote Access VPN allows individual use connect securely to a private network from a remote location.
Connection Type	It connects one network to another network such as branch office to head office.	It connects a single user device like a laptop or smartphone to the organization's network.
Users	Used by organizations to connect multiple offices or branch networks.	Used by employees or users working from home or traveling.
Authentication	Usually uses gateway devices like routers or firewalls for authentication between networks.	Requires user authentication such as username, password, or multi-factor authentication.
Access Method	Provides automatic secure connection between two company networks.	Requires VPN client software installed on the user's device.
Main Purpose	Mainly used for secure communication between company offices.	Mainly used for secure remote access to company resources by individuals.
Example	Connecting a company's headquarters network with branch office networks.	An employee securely accessing company servers from home using a VPN client.

Copy table

21) what is IP security and their features.

What is IP Security (IPSec)

1. **Definition** – Internet Protocol Security (IPSec) is a set of security protocols used to protect data transmitted over IP networks. It ensures secure communication by encrypting and authenticating IP packets.
2. **Network Layer Security** – IPSec operates at the network layer of the OSI model and secures communication between devices such as computers, servers, or routers.

3. **Secure Data Transmission** – IPSec protects data sent across public networks like the internet by ensuring confidentiality, integrity, and authentication of the transmitted data.
4. **Use in VPN** – IPSec is widely used in Virtual Private Networks (VPNs) to create secure tunnels between networks or remote users.

Features of IP Security (IPSec)

1. **Data Encryption** – IPSec encrypts data packets during transmission so that unauthorized users cannot read the information.
2. **Authentication** – IPSec verifies the identity of communicating devices to ensure that the data comes from a trusted source.
3. **Data Integrity** – IPSec ensures that the transmitted data is not altered or modified during transmission.
4. **Confidentiality** – By encrypting data, IPSec keeps sensitive information private and protected from attackers.
5. **Security Protocols** – IPSec uses protocols such as Authentication Header (AH) and Encapsulating Security Payload (ESP) to secure network communication.
6. **Secure Tunneling** – IPSec creates a secure tunnel between networks or devices, protecting data as it travels across public networks.
7. **Replay Protection** – IPSec prevents attackers from capturing and retransmitting data packets to gain unauthorized access.
8. **Flexible Implementation** – IPSec can be implemented in host-to-host, site-to-site, or remote access VPN configurations to secure different types of network communication.

22) what is cybersecurity forensics.

Cybersecurity Forensics

1. **Definition** – Cybersecurity forensics (or digital forensics) is the process of identifying, collecting, preserving, analyzing, and presenting digital evidence related to cybercrimes or security incidents.
2. **Investigation of Cyber Attacks** – It helps investigators determine how a cyber attack occurred, what systems were affected, and what actions the attacker performed during the incident.
3. **Collection of Digital Evidence** – Cyber forensics involves gathering digital evidence such as system logs, files, emails, network traffic, and malware samples from computers or networks.
4. **Evidence Preservation** – During forensic investigation, digital evidence must be preserved carefully to maintain its integrity and ensure that it is not modified or damaged.
5. **Analysis of Data** – Investigators analyze collected evidence to identify suspicious activities, unauthorized access, or malicious programs involved in the attack.

6. **Timeline Reconstruction** – Cyber forensics helps reconstruct the sequence of events during a security incident to understand when and how the attack took place.
7. **Supporting Legal Investigations** – The evidence collected during digital forensic investigations can be used in courts or legal proceedings to prove cybercrime activities.
8. **Improving Security Measures** – The results of forensic investigations help organizations identify vulnerabilities and improve their cybersecurity defenses to prevent future attacks.

23) Explain uses of digital evidence.

Uses of Digital Evidence

1. **Incident Investigation and Response** – Digital evidence helps investigators determine how a cyber attack occurred by analyzing logs, network traffic, and system activities to identify the source and method of the attack.
2. **Understanding Attack Methods** – Evidence such as malware samples, suspicious files, and system behavior provides information about the tools and techniques used by attackers during a cyber incident.
3. **Timeline Reconstruction** – Digital evidence allows investigators to create a timeline of events, showing when the attack started, what actions were taken, and how the systems were affected.
4. **Forensic Analysis** – It helps experts recover deleted files, analyze system logs, and examine digital artifacts to understand attacker activities and system compromises.
5. **Legal Proceedings** – Digital evidence can be presented in courts to prove cybercrime activities, support investigations, and establish the involvement of suspects in criminal cases.
6. **Threat Attribution** – Investigators use digital evidence such as IP addresses, malware signatures, and attack patterns to identify or trace the attackers responsible for cyber incidents.
7. **Compliance and Reporting** – Organizations use digital evidence to document security incidents and provide reports required for regulatory compliance or internal investigations.
8. **Preventing Future Attacks** – By analyzing digital evidence from past incidents, organizations can identify vulnerabilities and improve their security measures to prevent similar attacks in the future.

24) role of attribution in a cyber security investigation.

Role of Attribution in a Cybersecurity Investigation

1. **Identifying the Source of Attack** – Attribution helps investigators determine who is responsible for the cyber attack, such as cybercriminals, hacktivists, or nation-state actors.
2. **Understanding the Attacker's Motive** – By identifying the attacker, investigators can understand the purpose of the attack such as financial gain, espionage, or political objectives.
3. **Analyzing Attack Techniques** – Attribution helps analyze the tools, techniques, and procedures (TTPs) used by attackers, which helps security teams understand how the attack was carried out.
4. **Assessing Attack Sophistication** – It helps determine whether the attack was simple or highly advanced by analyzing the resources, skills, and technologies used by the attackers.
5. **Determining the Scope of the Attack** – Attribution helps investigators understand whether the attack was isolated or part of a larger coordinated campaign targeting multiple organizations.
6. **Supporting Incident Response** – Knowing the attacker helps security teams design appropriate response strategies and quickly contain the threat.
7. **Supporting Legal Actions** – Attribution provides evidence that can be used in legal investigations, criminal prosecution, or international actions against attackers.
8. **Improving Future Security** – Information gained from attribution helps organizations strengthen their security defenses and prevent similar attacks in the future.

25) what is master boot record (MBR).

Master Boot Record (MBR)

1. **Definition** – Master Boot Record (MBR) is the first sector of a storage device such as a hard disk that contains information required to start the operating system.
2. **Location** – MBR is stored in the first sector of the disk (sector 0) and is accessed by the computer during the booting process.
3. **Boot Loader** – It contains a small program called the boot loader that loads the operating system into the computer's memory during system startup.
4. **Partition Table** – MBR includes a partition table that stores information about the disk partitions and their locations on the storage device.
5. **Disk Structure Management** – It helps the system identify how the disk is divided into partitions and which partition contains the operating system.
6. **Boot Process Role** – When the computer is turned on, the BIOS reads the MBR and executes the boot loader to begin loading the operating system.
7. **Limited Partition Support** – The traditional MBR supports up to four primary partitions and has limitations compared to modern partition systems.

8. **Security Importance** – If the MBR becomes corrupted or infected by malware, the system may fail to boot, making it an important component in digital forensics and cybersecurity investigations.

26) difference between MBR and GUID partition Table.

Basis	MBR (Master Boot Record)	GPT (GUID Partition Table)
Full Form	MBR stands for **Master Boot Record**.	GPT stands for **GUID Partition Table**.
Disk Size Support	MBR supports disk sizes up to **2 TB** only.	GPT supports **very large disk sizes** greater than 2 TB.
Number of Partitions	MBR allows only **4 primary partitions** on a disk.	GPT allows **many partitions** (commonly up to 128).
Partition Information	In MBR, partition information is stored in a **single partition table**.	In GPT, partition information is stored in **multiple tables for better reliability**.
Booting System	MBR works with **Legacy BIOS systems**.	GPT works with **UEFI firmware systems**.
Data Protection	MBR has **less protection** because the partition table exists in one place.	GPT provides **better data protection** by storing backup partition tables.
Recovery Capability	If the MBR is corrupted, it can be difficult to recover the disk structure.	GPT can **recover easily** because it keeps backup copies of partition data.
Modern Usage	MBR is an **older partitioning system** used in traditional systems.	GPT is a **modern and more advanced partitioning system** used in newer computers.

27) Limitations of Master Boot Record.

1. **Limited Disk Size Support** – MBR can only support disk sizes up to **2 TB**, which makes it unsuitable for modern large storage devices.
2. **Limited Number of Partitions** – MBR allows only **four primary partitions**, which restricts the number of partitions that can be created on a disk.
3. **Single Partition Table** – MBR stores partition information in only one location, so if it becomes corrupted, the entire disk structure may become inaccessible.
4. **Lower Data Protection** – MBR does not provide backup copies of partition tables, which increases the risk of data loss if the record is damaged.
5. **Compatibility with Legacy BIOS** – MBR works mainly with **legacy BIOS systems** and is not optimized for modern **UEFI-based systems**.
6. **Higher Risk of Boot Failure** – If the MBR becomes corrupted due to malware or system errors, the operating system may fail to boot.
7. **Limited Partition Management** – Managing partitions in MBR is less flexible compared to modern partitioning systems like GPT.
8. **Less Suitable for Modern Systems** – Due to its limitations in disk size, security, and reliability, MBR is gradually being replaced by GPT in modern computers.

28) what is Master File Table.

1. **Master File Table (MFT)** is a special file used in the **NTFS file system** that stores detailed information about every file and folder on a disk.
2. It acts like a **database or index** that keeps records of all files, directories, and their attributes stored on the storage device.
3. Each file or folder in the NTFS system has a **separate record entry** in the Master File Table.
4. The MFT stores important information such as **file name, size, location, permissions, and creation or modification time**.
5. It helps the operating system **quickly locate and access files** stored on the disk.
6. Even the **MFT itself is treated as a file** within the NTFS file system.
7. If a file is deleted, its entry may still remain in the **Master File Table until it is overwritten**, which is useful in digital forensic investigations.
8. The Master File Table plays an **important role in file management and recovery**, helping the system organize and track all data stored on the disk.

29) Structure of MFT record.

1. **File Record Header** – The MFT record begins with a header that contains important information such as the record type, record size, and status of the file entry.
2. **File Signature** – Each MFT record starts with a signature called **"FILE"**, which identifies the record as a valid file entry in the NTFS file system.

3. **Fixup Values** – Fixup values are used to detect corruption in the MFT record and help maintain the integrity of the file system.
4. **Log Sequence Number (LSN)** – This field keeps track of changes made to the file record and helps in maintaining consistency during system recovery.
5. **Sequence Number** – The sequence number identifies how many times the file record has been reused or modified in the file system.
6. **File Attributes** – MFT records contain attributes such as file name, file size, timestamps, and permissions related to the file or directory.
7. **Data Attribute** – This section stores information about the actual location of the file data on the disk, either inside the MFT record or in other disk clusters.
8. **End Marker** – The MFT record ends with an end marker that indicates the end of attributes and the completion of the file record structure.

30) explain Cyber security or what is role of cyber security in an Organization.

Cyber Security / Role of Cyber Security in an Organization

1. **Protection of Sensitive Data** – Cybersecurity protects important organizational data such as customer information, financial records, and intellectual property from unauthorized access or cyber attacks.
2. **Preventing Cyber Attacks** – It helps organizations defend against threats like malware, ransomware, phishing, and hacking attempts that can damage systems or steal information.
3. **Ensuring Network Security** – Cybersecurity protects the organization's networks, servers, and devices from unauthorized access and malicious activities.
4. **Maintaining Business Continuity** – By preventing security breaches and system failures, cybersecurity helps organizations maintain smooth operations without disruptions.
5. **Protecting Organizational Reputation** – Strong cybersecurity prevents data breaches that could damage the trust of customers, partners, and stakeholders.
6. **Compliance with Regulations** – Many organizations must follow cybersecurity regulations and standards to protect data and maintain legal compliance.
7. **Monitoring and Detecting Threats** – Cybersecurity systems continuously monitor networks and systems to detect suspicious activities and respond quickly to potential threats.
8. **Supporting Safe Digital Operations** – Cybersecurity enables organizations to safely use technologies such as cloud computing, online services, and digital communication systems.

31) what is incident Management.

1. **Incident Management** is the process used by organizations to identify, analyze, and respond to security incidents that may affect systems, networks, or data.
2. It helps organizations quickly detect security issues such as cyber attacks, system failures, or unauthorized access and take appropriate action to control the situation.
3. The main goal of incident management is to **minimize damage and restore normal operations** as quickly as possible.
4. It involves monitoring systems and networks continuously to detect unusual activities or potential security threats.
5. Once an incident is detected, the security team analyzes the problem to determine its cause, impact, and severity.
6. The incident response team then takes actions such as containing the attack, removing the threat, and recovering affected systems.
7. Proper documentation and reporting of incidents are also part of incident management to help organizations learn from past incidents.
8. Incident management improves an organization's cybersecurity posture by helping prevent similar incidents in the future.

32) what is IT incident Management.

1. **IT Incident Management** is the process used to identify, analyze, and resolve unexpected issues or disruptions in IT services to restore normal operations as quickly as possible.
2. It focuses on minimizing the impact of incidents such as system failures, network outages, software errors, or security breaches on business operations.
3. IT incident management involves detecting incidents through monitoring systems, user reports, or automated alerts.
4. Once an incident is detected, the IT team analyzes the problem to understand its cause, severity, and impact on the organization.
5. The incident is then prioritized based on its urgency and the level of disruption it causes to business services.
6. IT teams take corrective actions to resolve the issue and restore the affected systems or services.
7. After resolving the incident, detailed documentation and reports are created for future reference and analysis.
8. IT incident management helps organizations maintain reliable IT services, improve response time, and prevent similar incidents in the future.

33) what is IDS and common method of intrusion.

What is IDS (Intrusion Detection System)

1. **Intrusion Detection System (IDS)** is a security tool used to monitor network traffic or system activities to detect suspicious behavior or unauthorized access.
2. IDS helps identify potential cyber attacks such as malware, hacking attempts, and unauthorized system access.
3. It continuously analyzes network packets and system logs to detect abnormal activities that may indicate a security breach.
4. When an intrusion or suspicious activity is detected, IDS generates alerts so that security administrators can take appropriate action.

Common Methods of Intrusion

1. **Password Attacks** – Attackers try to gain unauthorized access by guessing or cracking user passwords using techniques like brute force or dictionary attacks.
2. **Malware Attacks** – Intruders use malicious software such as viruses, worms, or trojans to infect systems and gain control over them.
3. **Denial of Service (DoS) Attacks** – Attackers overload a system or network with excessive traffic to make services unavailable to legitimate users.
4. **Man-in-the-Middle Attack** – In this attack, the attacker secretly intercepts communication between two parties to steal or modify information.
5. **Phishing Attacks** – Attackers trick users into revealing sensitive information like passwords or financial details through fake emails or websites.
6. **Exploiting Software Vulnerabilities** – Hackers take advantage of security weaknesses in software or operating systems to gain unauthorized access.
7. **Insider Attacks** – Employees or authorized users misuse their access privileges to steal or damage organizational data.
8. **Network Sniffing** – Attackers capture network traffic to obtain sensitive information such as login credentials and confidential data.

34) Explain working of IDS.

1. **Data Collection** – IDS collects data from network traffic, system logs, and host activities to monitor what is happening in the system or network environment.
2. **Monitoring Network and System Activities** – The IDS continuously monitors packets, user actions, and system processes to detect any suspicious or unusual behavior.
3. **Analysis of Collected Data** – The collected information is analyzed using predefined rules, patterns, or signatures to identify possible security threats.
4. **Signature-Based Detection** – IDS compares network activities with a database of known attack signatures to identify known types of cyber attacks.

5. **Anomaly-Based Detection** – IDS also detects unusual behavior by comparing current activities with normal system behavior to identify unknown or new threats.
6. **Alert Generation** – When suspicious activity or an intrusion attempt is detected, the IDS generates alerts or notifications for security administrators.
7. **Logging of Security Events** – IDS records detected events and activities in logs, which can be used for investigation and forensic analysis.
8. **Security Response Support** – The alerts and logs generated by IDS help security teams analyze threats and take appropriate actions to protect the network.

35) Classification of IDS.

Classification of Intrusion Detection System (IDS)

1. **Network-Based Intrusion Detection System (NIDS)** – NIDS monitors network traffic across the entire network to detect suspicious activities or attacks by analyzing data packets traveling through the network.
2. **Host-Based Intrusion Detection System (HIDS)** – HIDS is installed on individual computers or servers and monitors system files, logs, and activities to detect unauthorized access or changes.
3. **Signature-Based IDS** – This type of IDS detects attacks by comparing network activities with a database of known attack signatures or patterns.
4. **Anomaly-Based IDS** – Anomaly-based IDS detects intrusions by identifying abnormal behavior that differs from the normal activities of the system or network.
5. **Protocol-Based IDS (PIDS)** – PIDS monitors and analyzes the communication between devices using specific network protocols to detect suspicious protocol activity.
6. **Application-Based IDS (APIDS)** – APIDS monitors specific applications and analyzes their activities to detect attacks targeting application vulnerabilities.
7. **Hybrid IDS** – Hybrid IDS combines different IDS techniques such as signature-based and anomaly-based detection to improve threat detection accuracy.
8. **Wireless Intrusion Detection System (WIDS)** – WIDS monitors wireless networks to detect unauthorized devices, suspicious connections, and attacks targeting Wi-Fi networks.

36) what is evasion techniques.

1. **Evasion techniques** are methods used by attackers to bypass or avoid detection by security systems such as Intrusion Detection Systems (IDS), firewalls, or antivirus software.
2. These techniques help attackers hide their malicious activities so that security monitoring tools cannot easily identify the attack.

3. Attackers often modify or disguise malicious data packets to make them appear as normal network traffic.
4. One common technique is **packet fragmentation**, where attackers split malicious packets into smaller pieces so that IDS systems cannot properly analyze them.
5. Another technique is **encryption**, where attackers encrypt their malicious traffic to hide the content from security monitoring tools.
6. Attackers may also use **obfuscation**, which changes the appearance of malicious code to avoid signature-based detection systems.
7. **Protocol manipulation** is another evasion technique where attackers exploit weaknesses in network protocols to bypass detection systems.
8. Evasion techniques make cyber attacks harder to detect and require advanced security tools and continuous monitoring to prevent them.

37) types of evasion techniques.

1. **Fragmentation Attacks** – In this technique, attackers divide malicious packets into smaller fragments so that intrusion detection systems cannot properly analyze the complete packet.
2. **Encryption-Based Evasion** – Attackers encrypt malicious traffic to hide the content of the communication, making it difficult for IDS or security tools to inspect the data.
3. **Obfuscation Technique** – Attackers modify or disguise malicious code so that it does not match known attack signatures used by security systems.
4. **Protocol Manipulation** – In this technique, attackers exploit weaknesses or irregularities in network protocols to bypass intrusion detection systems.
5. **Session Splicing** – Attackers send malicious data in small segments over multiple packets to avoid detection by IDS systems.
6. **Traffic Flooding** – Attackers generate a large amount of network traffic to overwhelm the detection system and hide malicious activities within normal traffic.
7. **Timing Attacks** – Attackers send packets slowly over time so that intrusion detection systems fail to recognize the attack pattern.
8. **Packet Reordering** – Attackers change the order of packets so that security systems cannot properly reassemble the data and detect the attack.

38) what is packet fragmentation in evasion techniques.

1. **Packet fragmentation** is an evasion technique used by attackers to divide large network packets into smaller fragments before sending them across the network.
2. This technique is used to bypass security systems such as Intrusion Detection Systems (IDS) and firewalls that inspect network traffic for malicious activities.

3. When a packet is fragmented, the IDS may analyze each fragment separately instead of the complete packet.
4. Because the fragments are analyzed individually, the IDS may fail to detect malicious patterns contained in the full packet.
5. Attackers intentionally split malicious payloads into multiple fragments so that detection systems cannot easily identify the attack.
6. The destination system later reassembles the fragments to reconstruct the original packet.
7. Once the fragments are reassembled, the hidden malicious code or attack payload becomes active on the target system.
8. Packet fragmentation makes intrusion detection more difficult and is commonly used to evade network security monitoring tools.

1. Types of Digital Forensic Evidence

1. **Data from Devices** – Digital forensic evidence can come from devices such as computers, laptops, smartphones, hard drives, and USB storage that contain files, documents, and other digital information.
2. **System and Application Logs** – Logs generated by operating systems and applications record user activities, login attempts, and system events that can help investigators trace cyber incidents.
3. **Network Traffic Data** – Network evidence includes packet captures, firewall logs, and router records that show communication between systems and possible malicious activity.
4. **Metadata** – Metadata is data about data, such as file creation time, modification date, and access history, which helps investigators understand how and when files were used.
5. **Emails and Messaging Data** – Email records, chat messages, and communication logs can provide evidence of suspicious communication or planning of cyber activities.
6. **Digital Footprints** – Information like browsing history, cookies, IP addresses, and social media activity can help trace the online behavior of a suspect.
7. **Cloud Data** – Data stored in cloud services such as cloud storage logs, account access records, and uploaded files can also be used as digital forensic evidence.
8. **Malware and Program Files** – Suspicious software, malicious code, or infected program files found on a system can provide evidence of cyber attacks or unauthorized activities.

2. understanding best, corroborating and indirect of circumstances evidence

Best Evidence

1. Best evidence is the **most direct and reliable form of evidence** used in an investigation or legal case to prove a particular fact.
2. It usually refers to the **original document or digital file** rather than copies or secondary versions.
3. In digital forensics, examples include **original system logs, original files, or unaltered digital recordings**.
4. Best evidence directly proves the fact without requiring additional interpretation or assumptions.
5. Courts prefer best evidence because it provides the **most accurate and trustworthy information** about an event.
6. An example of best evidence is an **original email or original digital document** related to a cybercrime.
7. In cybersecurity investigations, best evidence helps establish **clear proof of unauthorized activities**.
8. Proper preservation of best evidence is important to ensure its **integrity and admissibility in legal proceedings**.

Corroborating Evidence

1. Corroborating evidence is evidence that **supports or strengthens other evidence** in an investigation.
2. It does not prove a fact alone but **confirms or validates the main evidence** presented.
3. Multiple sources of evidence are used together to make the investigation more reliable.
4. For example, **system logs supporting an email record** can act as corroborating evidence.
5. It helps investigators verify the **accuracy of statements or primary evidence**.
6. In cyber investigations, network logs may support the evidence of a suspicious login activity.
7. Corroborating evidence improves the **credibility and reliability of the investigation**.
8. It helps investigators build a stronger case by confirming the findings of other evidence.

Indirect (Circumstantial) Evidence

1. Indirect or circumstantial evidence is evidence that **suggests a fact indirectly** rather than proving it directly.
2. It requires logical reasoning or inference to connect the evidence with the conclusion.
3. For example, **finding a suspect's IP address in server logs** may indicate involvement in an attack.
4. This type of evidence does not directly show the crime but **implies that the suspect may be responsible**.
5. In digital forensics, browsing history or login records may serve as circumstantial evidence.
6. A single piece of circumstantial evidence may not prove guilt, but **multiple pieces together can build a strong case**.

7. Investigators often combine indirect evidence with other types of evidence for better accuracy.
8. Circumstantial evidence is widely used when **direct evidence is unavailable or limited**.

3. Steps for collecting evidence from mobile device

1. **Preparation and Authorization** – Before collecting evidence, investigators must obtain proper legal authorization and prepare the required forensic tools to ensure the investigation follows legal and organizational policies.
2. **Securing the Device** – The mobile device should be isolated from networks by turning on airplane mode or placing it in a Faraday bag to prevent remote access or data modification.
3. **Documenting the Device** – Investigators record important details such as device model, serial number, SIM information, physical condition, and screen status for proper documentation.
4. **Preserving Volatile Data** – If the device is powered on, volatile data such as running applications, network connections, and memory information should be preserved before shutting down the device.
5. **Creating a Forensic Image** – A complete forensic copy of the mobile device storage is created using specialized forensic tools to ensure the original data remains unchanged.
6. **Maintaining Chain of Custody** – Proper records are maintained to track who collected, handled, and analyzed the evidence to maintain its integrity for legal purposes.
7. **Analyzing the Collected Data** – Investigators examine the extracted data such as messages, call logs, emails, photos, and application data to identify relevant evidence.
8. **Reporting the Findings** – Finally, the results of the forensic analysis are documented in a detailed report that can be used for investigation, legal proceedings, or incident response.

4. Steps for Collecting Evidence from Network Infrastructure Devices

1. **Identify Relevant Network Devices** – Investigators first identify network infrastructure devices such as routers, switches, firewalls, and intrusion detection systems that may contain useful evidence.
2. **Obtain Authorization** – Proper legal permission and organizational approval must be obtained before collecting evidence from network devices.
3. **Preserve Network Logs** – Important logs such as firewall logs, router logs, and IDS logs should be preserved immediately to prevent them from being overwritten.

4. **Document the Network Environment** – Investigators record details about the network configuration, device settings, IP addresses, and network topology.
5. **Collect Configuration Files** – Configuration files from routers, switches, and firewalls are collected to understand network settings and possible security weaknesses.
6. **Capture Network Traffic** – Network packet captures may be collected using monitoring tools to analyze communication and detect suspicious activities.
7. **Maintain Chain of Custody** – Proper documentation is maintained to track who collected and handled the evidence to ensure its integrity.
8. **Analyze and Store Evidence** – The collected logs, traffic data, and configuration files are securely stored and analyzed to identify cyber attacks or unauthorized access.

5. **Explain IPS and its types**

Intrusion Prevention System (IPS)

1. **Intrusion Prevention System (IPS)** is a network security technology that monitors network traffic to detect and prevent malicious activities or cyber attacks in real time.
2. IPS analyzes network packets and system activities to identify suspicious behavior or known attack patterns.
3. When a threat is detected, IPS can automatically block or prevent the attack by dropping malicious packets or stopping the connection.
4. It works actively to protect systems by preventing unauthorized access, malware infections, and network exploitation attempts.

Types of Intrusion Prevention System (IPS)

1. **Network-Based IPS (NIPS)** – NIPS monitors and analyzes network traffic across an entire network to detect and block malicious activities before they reach target systems.
2. **Host-Based IPS (HIPS)** – HIPS is installed on individual devices such as servers or computers and monitors system activities to prevent unauthorized access or changes.
3. **Wireless IPS (WIPS)** – WIPS monitors wireless networks to detect unauthorized devices, suspicious connections, and attacks targeting Wi-Fi networks.
4. **Network Behavior Analysis IPS (NBA)** – This type of IPS analyzes network traffic patterns to detect abnormal activities such as Distributed Denial of Service (DDoS) attacks or unusual network behavior.

6. **Why do you need an IPS?**

1. **Prevent Cyber Attacks** – IPS helps detect and block cyber attacks such as malware, worms, and hacking attempts before they can harm the network or systems.
2. **Real-Time Threat Protection** – It monitors network traffic continuously and takes immediate action to stop malicious activities as soon as they are detected.
3. **Improved Network Security** – IPS strengthens the overall security of an organization's network by preventing unauthorized access and suspicious activities.
4. **Protection Against Exploits** – It protects systems from vulnerabilities and exploits that attackers may use to gain unauthorized access.
5. **Automatic Response to Threats** – Unlike IDS, IPS can automatically block malicious traffic, terminate connections, or prevent harmful packets from entering the network.
6. **Reduced Security Risks** – By preventing attacks early, IPS reduces the risk of data breaches, system damage, and service disruptions.
7. **Monitoring Network Activities** – IPS analyzes network packets and system behavior to identify abnormal patterns that may indicate a cyber attack.
8. **Support for Security Policies** – It helps enforce organizational security policies by controlling and filtering network traffic based on defined rules.

7. **Explain common security log sources**

Common Security Log Sources

1. **Operating System Logs** – These logs record activities within the operating system such as user logins, system errors, and file access attempts, helping investigators detect unauthorized actions.
2. **Firewall Logs** – Firewall logs track incoming and outgoing network traffic and record blocked or allowed connections, which helps identify suspicious network access attempts.
3. **Intrusion Detection/Prevention System Logs (IDS/IPS)** – These logs contain information about detected intrusions, suspicious activities, and security alerts generated by IDS or IPS tools.
4. **Application Logs** – Application logs record events related to specific software applications such as login attempts, transactions, and application errors.
5. **Web Server Logs** – Web server logs track user requests to websites, including IP addresses, accessed pages, and request times, which help detect malicious web activities.
6. **Database Logs** – Database logs store information about database activities such as queries, updates, login attempts, and data modifications.
7. **Network Device Logs** – Logs generated by routers, switches, and other network devices record network events and configuration changes that help analyze network security incidents.
8. **Authentication Logs** – These logs track user authentication activities such as login successes, login failures, and password changes, helping identify unauthorized access attempts.

8. **What is Active attack?**

1. **Active attack** is a type of cyber attack in which an attacker actively interferes with or modifies the communication or operation of a system or network.
2. In this attack, the attacker attempts to **alter, disrupt, or destroy data** while it is being transmitted between users or systems.
3. Active attacks often involve actions such as **inserting malicious data, modifying messages, or blocking communication**.
4. The main objective of an active attack is to **damage systems, gain unauthorized access, or interrupt normal network operations**.
5. Unlike passive attacks, active attacks **directly affect the system's performance or data integrity**.
6. Common examples include **Denial of Service (DoS), Man-in-the-Middle attacks, and session hijacking**.
7. These attacks are usually easier to detect because they **cause noticeable changes or disruptions in the system or network**.
8. Active attacks can lead to **data loss, service interruption, and security breaches** if not detected and prevented quickly.

9. **Explain Masquerade attack/ Repudiation/ DOS attack**

Masquerade Attack

1. A **Masquerade attack** occurs when an attacker pretends to be a legitimate user to gain unauthorized access to a system or network.
2. The attacker may steal login credentials such as usernames and passwords to impersonate an authorized user.
3. Once access is gained, the attacker can perform actions such as viewing sensitive data or modifying system information.
4. Masquerade attacks often occur through methods like phishing, password cracking, or session hijacking.
5. This attack can compromise the confidentiality and integrity of organizational data.
6. It is difficult to detect because the attacker appears as a valid user in the system.
7. Strong authentication methods such as multi-factor authentication can help prevent masquerade attacks.
8. Regular monitoring of login activities can help identify unusual access attempts.

Repudiation Attack

1. A **Repudiation attack** occurs when a user denies performing an action or transaction within a system.
2. The attacker claims that they did not send a message or perform a particular activity.
3. This attack often occurs in systems where there is no proper logging or authentication.
4. Repudiation can lead to disputes because there is no clear proof of the user's actions.
5. It affects the accountability and trust within a system or organization.
6. Digital signatures and secure logging are used to prevent repudiation attacks.
7. Proper audit trails help track user actions and provide evidence if disputes occur.
8. Repudiation attacks are common in financial transactions and online communication systems.

Denial of Service (DoS) Attack

1. A **Denial of Service (DoS) attack** is an attack where a system or network is overwhelmed with excessive traffic.
2. The goal of the attack is to make the service unavailable to legitimate users.
3. Attackers send a large number of requests to the server to consume system resources.
4. As a result, the server becomes slow or completely stops responding to users.
5. DoS attacks can target websites, networks, or online services.
6. Distributed Denial of Service (DDoS) attacks use multiple systems to launch the attack.
7. These attacks can cause service disruptions and financial losses for organizations.
8. Security tools such as firewalls, intrusion prevention systems, and traffic filtering help mitigate DoS attacks.

10. What is passive attack?

1. **Passive attack** is a type of cyber attack where the attacker secretly monitors or listens to network communications without altering the data.
2. In this attack, the attacker attempts to **gather sensitive information** such as passwords, messages, or confidential data.
3. Passive attacks do not directly affect the system or network operation, making them **difficult to detect**.
4. The main objective of a passive attack is to **obtain information for future malicious activities**.
5. Attackers often use techniques like **network sniffing and traffic analysis** to capture data from communication channels.
6. Since the attacker does not modify the data, users usually remain unaware that their information is being monitored.

7. Passive attacks mainly target the **confidentiality of information** in a network.
8. Encryption and secure communication protocols are commonly used to protect systems from passive attacks.

Types of Evasion Technique For IDS

Last Updated : 23 Jul, 2025

IDS stands for Intrusion Detection System. It is used to monitor traffic entering any network and helps in detecting malicious activity. It is important to note that IDS only detects malicious activities, and does not prevent attacks.

This article describes various techniques to evade IDS (Intrusion Detection System) and their implementation using the NMAP tool.

Organizations might have IDS in place to monitor network traffic before packets are routed to their internal networks. IDS employs various methods to detect suspicious activities:

- Anomaly-based
- Signature-based
- Host-based
- Network-based

Please refer to the article Intrusion Detection System (IDS) to know more about IDS.

Types of Evasion Techniques:

Like any other system, IDS have vulnerabilities that can be exploited by attackers to evade them.

1. Packet Fragmentation: In this technique, the IP packets are split into smaller fragments. By doing this, the TCP header is split across multiple fragments. When IDS encounter the packets, they enqueue them for checking any malicious activity. However, as the number of fragments increases, there is an increase in the CPU and network bandwidth consumption. For this reason, IDS ignores evaluating such packets. Hence, these fragments may pass undetected through the IDS.

```
aayush@aayush-HP-Laptop-14s-cf1xxx:~$ sudo nmap -f 127.0.0.1
Starting Nmap 7.80 ( https://nmap.org ) at 2022-06-23 22:09 IST
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000012s latency).
Not shown: 994 closed ports
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
23/tcp   open  telnet
80/tcp   open  http
631/tcp  open  ipp
9091/tcp open  xmltec-xmlmail
```

The -f flag is used to create fragments. So the packet after the IP header is broken down into fragments of size 8 bytes or less. For example, if the size of the packet after the IP header is 10 bytes, then it will be split into two fragments of size 8 bytes and 2 bytes respectively. Specifying -f twice would create fragments of size 16 bytes. We can also specify our own size using -mtu flag. However, the size must be a multiple of 8. The fragments created using the above command can be captured using Wireshark.

The above picture shows frame 6125 sent to 127.0.0.1. The highlighted part shows that this frame was reassembled in IP frame 6127. Hence, we can conclude that frame 6125 was a part of frame 6127, and fragmentation was done successfully.

2. Source Routing: Packets pass through a number of routers before reaching the target host. Routers consult the routing table to pass the packet to the next hop. IDS are also put in place to monitor the network traffic. However, the route taken by the packets can be manipulated by the attacker. The attacker can make sure that the packets take a route that does not contain the IDS.

3. Source Port Manipulation: Sometimes IDS might allow network packets to pass without any inspection if they arrive at a particular port like port 80 which is primarily used for HTTP. This improper configuration can be exploited by attackers by manipulating the source port of packets. Hence, packets arriving at such ports can go unnoticed by the IDS.

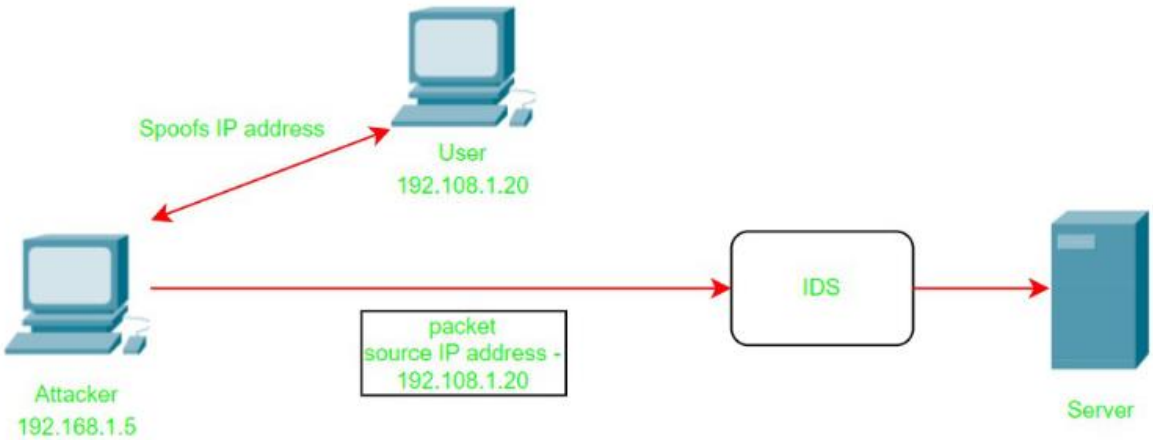
The --source-port or -g flag can be used for specifying the source port of packets. The image below shows the packets sent as a result of executing the above command. We can see that the source port of all SYN packets is 22.

4. IP Address Decoy: The attacker sends packets to the target host by using the IP addresses of other hosts. So different packets have different IP addresses. Hence, it becomes difficult for the IDS to identify the actual IP address of the attacker. However, one of the packets has the actual IP address of the attacker, and if the IDS is configured to block traffic from all these IP addresses then the attacker cannot evade the IDS. This technique is used to scan ports at the target host. So an attacker can identify whether a particular port at the target host is running or not.

```
aayush@aayush-HP-Laptop-14s-cf1xxx:~$ sudo nmap -D RND:10 127.0.0.1
Starting Nmap 7.80 ( https://nmap.org ) at 2022-06-23 23:21 IST
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000025s latency).
Not shown: 994 closed ports
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
23/tcp   open  telnet
80/tcp   open  http
631/tcp  open  ipp
9091/tcp open  xmltec-xmlmail
```

-D flag can be used for a decoy scan. RND option is used for generating random IP addresses. In the above example, 10 IP addresses were generated randomly and sent to the target host. We can see that packets were sent to the same target host from 10 different IP addresses including the actual IP address (127.0.0.1) of the attacker in the image below.

5. IP Address Spoofing: IP Address Spoofing simply means using some other machine's IP address to send packets to the target host. Again, this technique can be used to scan ports which are usually done before the actual attack. So the IDS may identify the innocent hosts as malicious ones. However, using NMAP for performing IP address spoofing won't produce useful results as the reply packets from the target host will be sent to the spoofed IP address. -S <ip-address> option can be used to perform IP address spoofing.



6. Customizing Packets: IDS can be evaded by customizing the data packets. Customizing can be done by replacing data in the payload or appending data to the payload. Following are some ways to customize data-

(a) Unicode-based Evasion: Unicode is used to represent characters from different languages, emojis, etc. So, the payload can contain Unicode representation of data. However, a message having the same meaning could be represented using a different Unicode. By replacing data in the payload, malicious packets can pass through a signature-based IDS if the newly created pattern is not a part of the signature set stored.

(b) Appending binary data: This appends binary data to the payload. The data to be appended must be specified in hexadecimal.

```
nmap <target ip-address> --data 0xabcdefab
```

(c) Appending string: This appends a regular string to the payload.

```
nmap <target ip-address> --data-string "danger"
```

(c) Appending string: This appends a regular string to the payload.

```
nmap <target ip-address> --data-string "danger"
```

(d) Appending random data: This appends random data of specified length to the payload. Length can be anything between 0-65400. However, values greater than 1400 are not recommended as they could be greater than MTU.

```
nmap <target ip-address> --data-length <length>
```